Week 3

Securing Networks

Tauseef Ahmed, PhD
t.ahmed4@uel.ac.uk



Lecture Objectives

Security Foundation

Security Devices

Securing Wireless network (WLANs)

Security Services

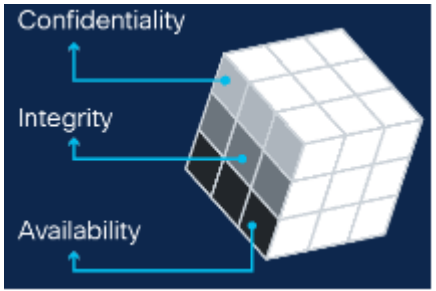
Types of Security Data

1. Security Foundations

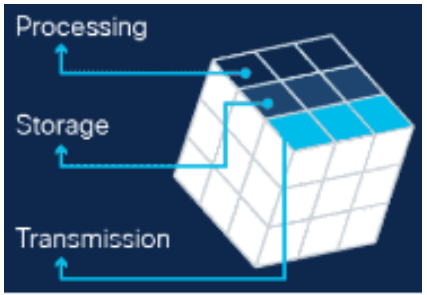
The Cybersecurity Cube

The cybersecurity cube provides a useful way to think about protecting data and includes the three dimensions of information security.

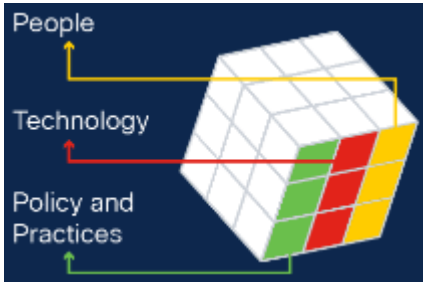
1. Security Principles
identify the goals to protect cyberspace.
- Data **confidentiality**
- Data **integrity**
- Data **availability**



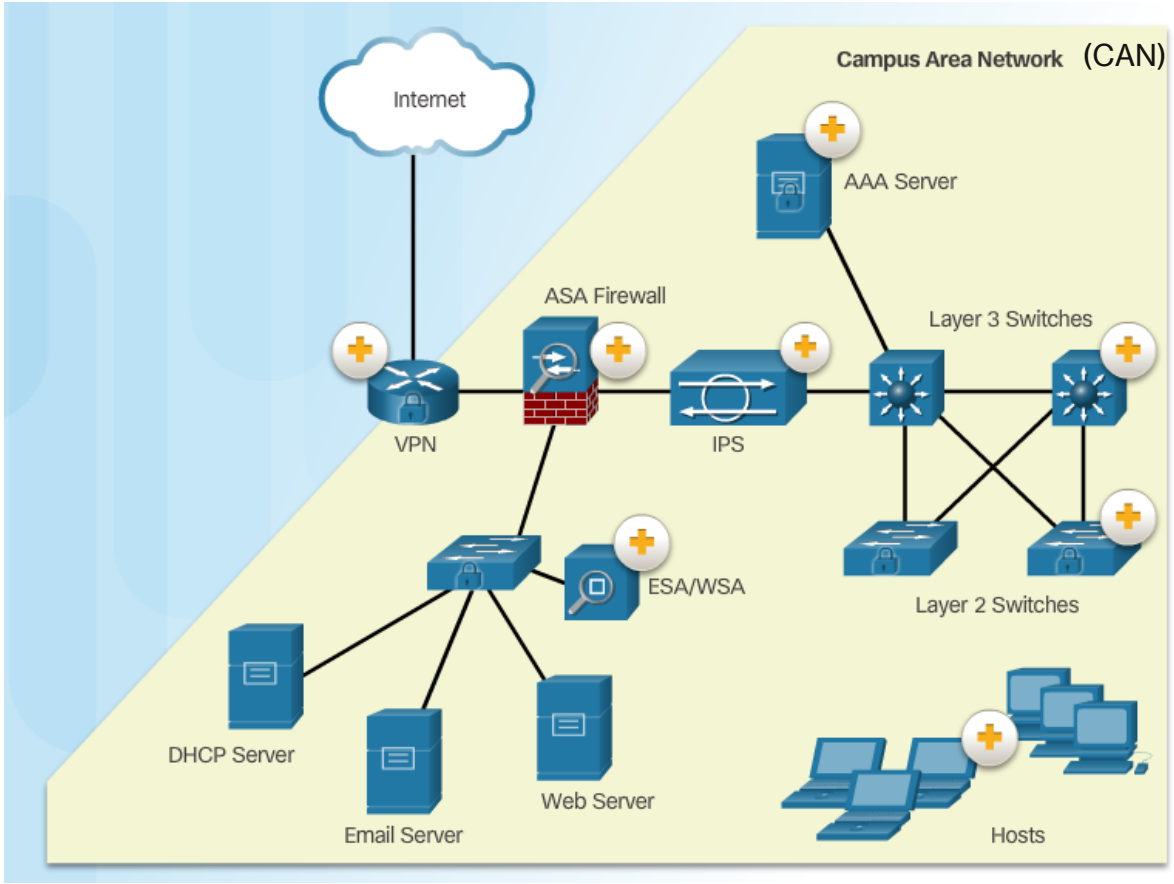
2. Data States
represent the three possible data states.
- Data **in transit**
- Data **at rest** or in storage
- Data **in process**



3. Safeguards
define the pillars on which to base our cybersecurity defenses to protect data and infrastructure in the digital realm.
- **Technology**
- **Policy and practices**
- Improving education, training, and awareness in **people**



Campus Area Networks



Campus Area Networks (CAN)

Term	Definition
VPN	The Cisco ISR is secured. It protects data in motion that is flowing from the CAN to the outside world by establishing Virtual Private Networks (VPNs). VPNs ensure data confidentiality and integrity from authenticated sources.
ASA Firewall	A Cisco Adaptive Security Appliance (ASA) firewall performs stateful packet filtering to filter return traffic from the outside network into the campus network.
IPS	A Cisco Intrusion Prevention System (IPS) device continuously monitors incoming and outgoing network traffic for malicious activity. It logs information about the activity and attempts to block and report it.
Layer 3 Switches	These distribution layer switches are secured and provide secure redundant trunk connections to the Layer 2 switches. Several different security features can be implemented, such as ACLs, DHCP snooping, Dynamic ARP Inspection (DAI), and IP source guard.
Layer 2 Switches	These access layer switches are secured and connect user-facing ports to the network. Several different security features can be implemented, such as port security, DHCP snooping, and 802.1X user authentication.
ESA/WSA	A Cisco Email Security Appliance (ESA) and Web Security Appliance (WSA) provide advanced threat defense, application visibility and control, reporting, and secure mobility to secure and control email and web traffic.
AAA Server	An authentication, authorization, and accounting (AAA) server authenticates users, authorizes what they are allowed to do, and tracks what they are doing.
Hosts	End points are secured using various features including antivirus and antimalware software, Host Intrusion Protection System features, and 802.1X authentication features.

2. Security Devices

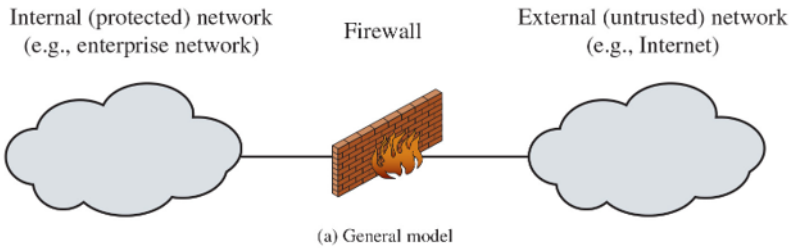
Firewalls

A firewall is a system, or group of systems, that enforces an access control policy between networks.

- Internet connectivity is essential
  - However, it creates a threat
- Effective means of protecting LAN s
- Inserted between the premises network and the Internet to establish a controlled link
  - Can be a single computer system or a set of two or more systems working together
- Used as a perimeter defense
  - Single choke point to impose security and auditing
  - Insulates the internal systems from external networks

Firewall Characteristics

- Design goals
  - All traffic from inside to outside, and vice versa, must pass through the firewall
  - Only authorized traffic as defined by the local security policy will be allowed to pass
  - The firewall itself is immune to penetration



(a) General model

Firewall Access Policy

- A critical component in the planning and implementation of a firewall is specifying a suitable access policy
  - This lists the types of traffic authorized to pass through the firewall
  - Includes address ranges, protocols, applications and content types
- This policy should be developed from the organization's information security risk assessment and policy
- Should be developed from a broad specification of which traffic types the organization needs to support
  - Then refined to detail the filter elements which can then be implemented within an appropriate firewall topology

Firewall Filter Characteristics (1 of 2)

- Characteristics that a firewall access policy could use to filter traffic include:
  - IP address and protocol values
    - This type of filtering is used by packet filter and stateful inspection firewalls
    - Typically used to limit access to specific services
  - Application protocol
    - This type of filtering is used by an application-level gateway that relays and monitors the exchange of information for specific application protocols

Firewall Filter Characteristics (2 of 2)

- User identity
  - Typically for inside users who identify themselves using some form of secure authentication technology
- Network activity
  - Controls access based on considerations such as the time of request, rate of requests, or other activity patterns

Firewall Capabilities And Limits

Firewall Benefits:

- They prevent the exposure of sensitive hosts, resources, and applications to untrusted users.
- They sanitize protocol flow, which prevents the exploitation of protocol flaws.
- They block malicious data from servers and clients.
- They reduce security management complexity by off-loading most of the network access control to a few firewalls in the network.



Firewall Limitations:

- A misconfigured firewall can have serious consequences for the network, such as becoming a single point of failure.
- The data from many applications cannot be passed over firewalls securely.
- Users might proactively search for ways around the firewall to receive blocked material, which exposes the network to potential attack.
- Network performance can slow down.
- Unauthorized traffic can be tunneled or hidden as legitimate traffic through the firewall.



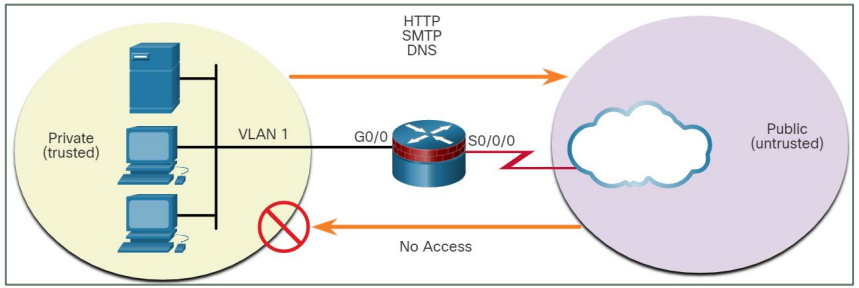
Common Security Architectures

Firewall design is primarily about device interfaces permitting or denying traffic based on the source, the destination, and the type of traffic. Three common firewall designs are:

Private and Public

The public network (or outside network) is untrusted, and the private network (or inside network) is trusted. Typically, a firewall with two interfaces is configured as follows:

- Traffic originating from the private network is permitted and inspected as it travels toward the public network. Inspected traffic returning from the public network and associated with traffic that originated from the private network is permitted.
- Traffic originating from the public network and traveling to the private network is generally blocked.



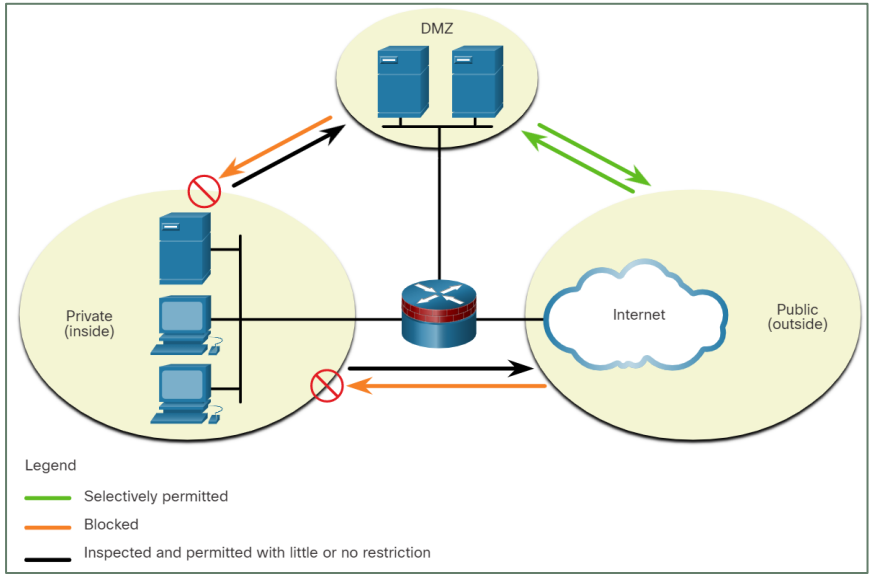
Common Security Architectures (Cont.)

Demilitarized Zone (DMZ)

A firewall design where there is typically one inside interface connected to the private network, one outside interface connected to the public network, and one DMZ interface.

Typical firewall DMZ configuration:

- Traffic originating from the private network is permitted and inspected as it travels toward the public network. Inspected traffic returning from the public network and associated with traffic that originated from the private network is permitted.
- Traffic originating from the public network and traveling to the private network is generally blocked.

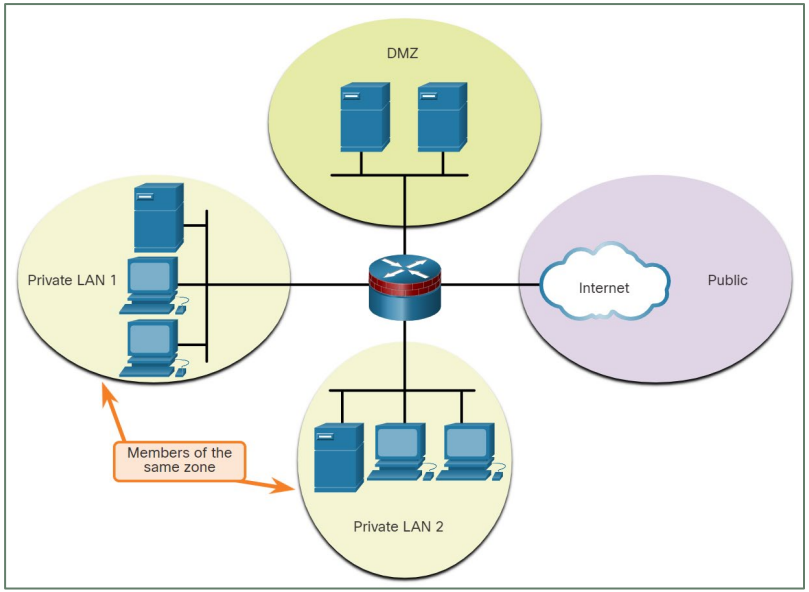


Common Security Architectures (Cont.)

Zone-Based Policy Firewalls (ZPFs)

ZPFs use zones to provide additional flexibility. A zone is a group of one or more interfaces that have similar functions or features. Zones are used to specify where a firewall rule or policy should be applied.

- Security policies for LAN 1 and LAN 2 are similar and can be grouped into a zone for firewall.
- The traffic between interfaces in the same zone is not subject to any policy and passes freely.
- All zone-to-zone traffic is blocked and to permit traffic between zones, a policy allowing or inspecting traffic must be configured.
- The only exception to this default *deny any* policy is the router self-zone.



Firewall Types

Four common types of firewalls are:

Firewall Type	Firewall Features
Packet Filtering (Stateless) Firewall	Packet filtering firewalls are usually part of a router firewall, which permits or denies traffic based on Layer 3 and Layer 4 information. They are stateless firewalls.
Stateful Firewall	Stateful firewalls provide stateful packet filtering by using connection information maintained in a state table. It analyzes traffic at OSI Layer 3 through 5.
Application Gateway Firewall	An application gateway firewall (proxy firewall) filters information at Layers 3, 4, 5, and 7 of the OSI model. Most of the firewall control and filtering is done in software.
Next Generation Firewalls	Next-generation firewalls (NGFW) go beyond stateful firewalls by providing integrated intrusion prevention, application awareness and control, upgrade paths to include future information feeds, and techniques to address evolving security threats.

Firewall Examples

- Packet-Filtering fw

Rule	Direction	Src address	Dest address	Protocol	Dest port	Action
1	In	External	Internal	TCP	25	Permit
2	Out	Internal	External	TCP	>1023	Permit
3	Out	Internal	External	TCP	25	Permit
4	In	External	Internal	TCP	>1023	Permit
5	Either	Any	Any	Any	Any	Deny

Firewall Examples

- Stateful Firewall Connection State Table

Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	210.9.88.29	80	Established
192.168.1.102	1031	216.32.42.123	80	Established
192.168.1.101	1033	173.66.32.122	25	Established
192.168.1.106	1035	177.231.32.12	79	Established
223.43.21.231	1990	192.168.1.6	80	Established
219.22.123.32	2112	192.168.1.6	80	Established
210.99.212.18	3321	192.168.1.6	80	Established
24.102.32.23	1025	192.168.1.6	80	Established
223.21.22.12	1046	192.168.1.6	80	Established

Other Firewall Types

- Other methods of implementing firewalls include:

- Host-based (server and personal) firewall - A PC or server with firewall software running on it.
- Transparent firewall - Filters IP traffic between a pair of bridged interfaces.
- Hybrid firewall - A combination of the various firewall types.

What is Intrusion and Intrusion Detection

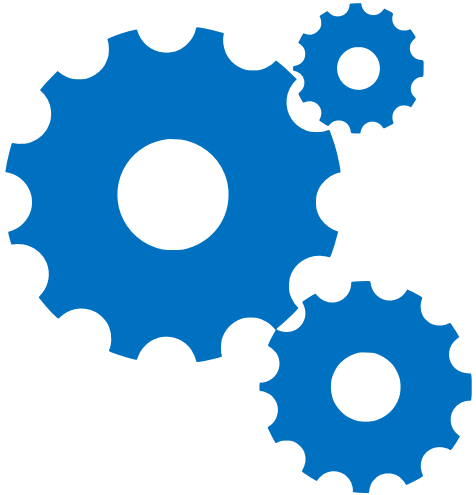
- **Security Intrusion:**
  - Unauthorized act of bypassing the security mechanisms of a system
- **Intrusion Detection:**
  - A hardware or software function that gathers and analyzes information from various areas within a computer or a network to identify possible security intrusions



Intrusion Detection System (IDS)

COMPONENTS

- Comprises three logical components:
  - Sensors - collect data
  - Analyzers - determine if intrusion has occurred
  - User interface - view output or control system behavior



TYPES

Host-based IDS (HIDS)

- Monitors the characteristics of a single host for suspicious activity

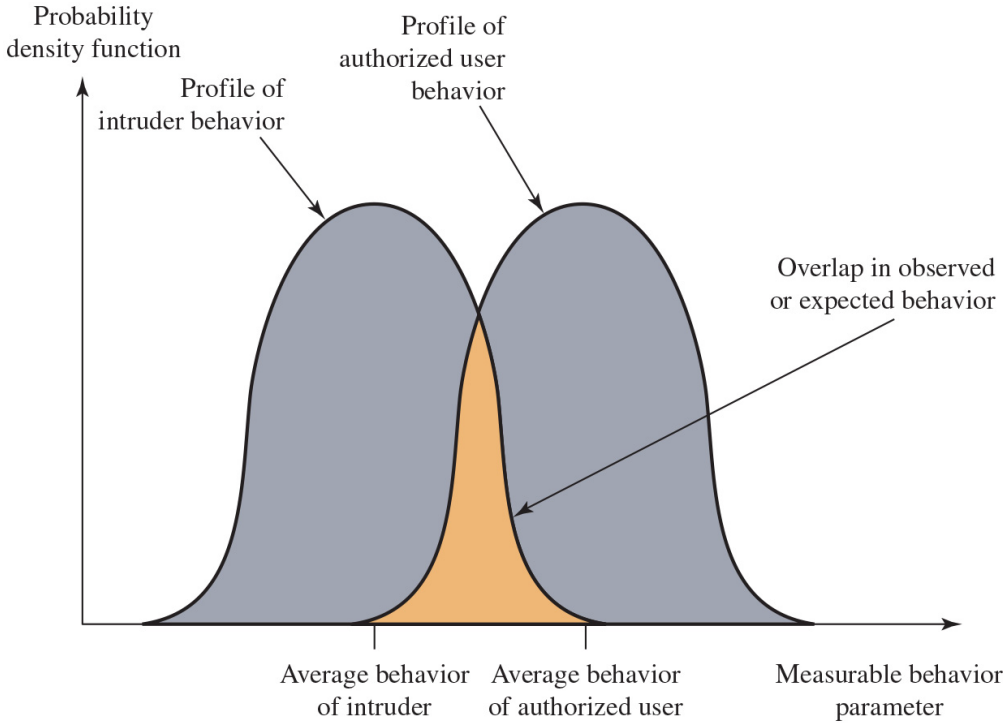
Network-based I D S (NIDS)

- Monitors network traffic and analyzes network, transport, and application protocols to identify suspicious activity

Distributed or hybrid IDS

- Combines information from a number of sensors, often both host- and network-based, in a central analyzer that is able to better identify and respond to intrusion activity

Profiles of Behavior of Intruders and Authorized Users



IDS Requirements

- Run continually
- Be fault tolerant
- Resist subversion
- Impose a minimal overhead on system
- Configured according to system security policies
- Adapt to changes in systems and users
- Scale to monitor large numbers of systems
- Provide graceful degradation of service
- Allow dynamic reconfiguration

Analysis Approaches

ANOMALY DETECTION

- Involves the collection of data relating to the behavior of legitimate users over a period of time
- Current observed behavior is analyzed to determine whether this behavior is that of a legitimate user or that of an intruder

SIGNATURE/HEURISTIC DETECTION

- Uses a set of known malicious data patterns or attack rules that are compared with current behavior
- Also known as misuse detection
- Can only identify known attacks for which it has patterns or rules

Anomaly Detection

- A variety of classification approaches are used:
  - Statistical
    - Analysis of the observed behavior using univariate, multivariate, or time-series models of observed metrics
  - Knowledge based
    - Approaches use an expert system that classifies observed behavior according to a set of rules that model legitimate behavior
  - Machine-learning
    - Approaches automatically determine a suitable classification model from the training data using data mining techniques



Signature or Heuristic Detection



Signature approaches

Match a large collection of known patterns of malicious data against data stored on a system or in transit over a network

The signatures need to be large enough to minimize the false alarm rate while still detecting a sufficiently large fraction of malicious data

Widely used in anti-virus products, network traffic scanning proxies, and NIDS



Rule-based heuristic identification

Involves the use of rules for identifying known penetrations or penetrations that would exploit known weaknesses

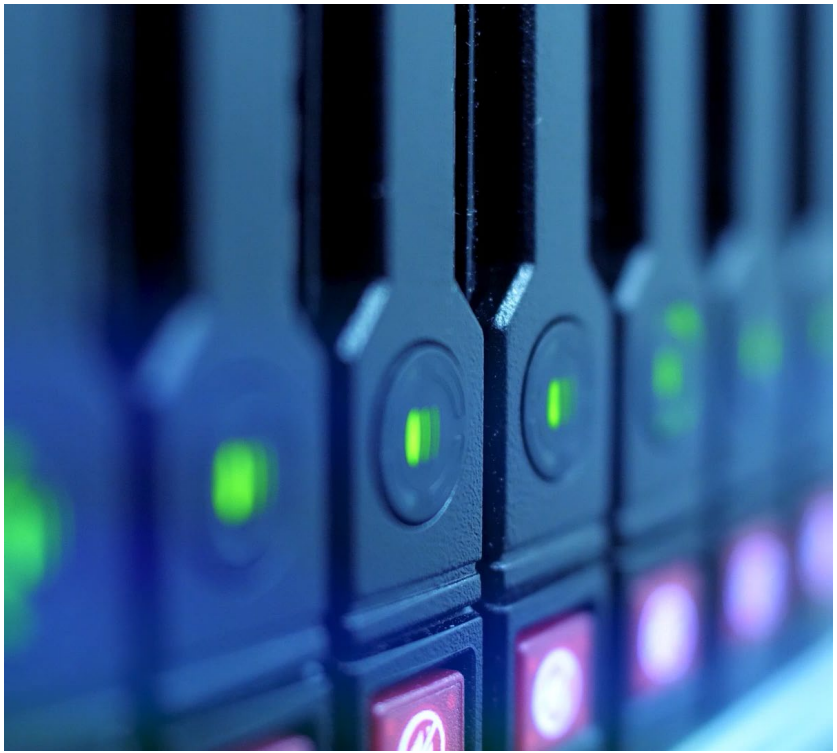
Rules that identify suspicious behavior can also be defined, even when the behavior is within the bounds of established patterns of usage

Typically rules used are specific

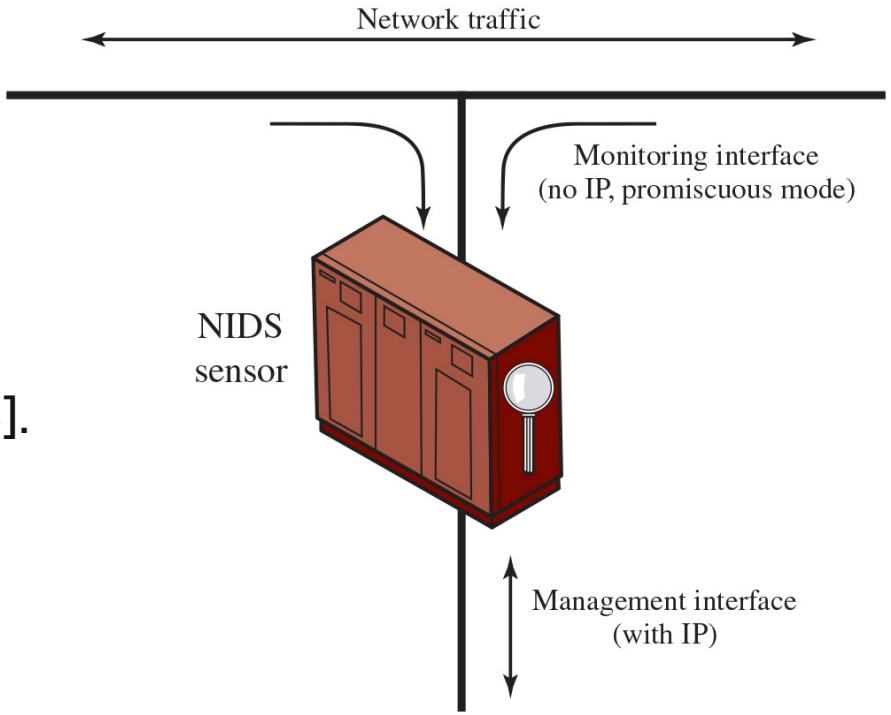
SNORT is an example of a rule-based NIDS

Network-Based IDS (NIDS)

- Monitors traffic at selected points on a network
- Examines traffic packet by packet in real or close to real time
- May examine network-, transport-, and/or application-level protocol activity
- Includes a number of sensors, one or more servers for NIDS management functions, and one or more management consoles for the human interface
- Analysis of traffic patterns may be done at the sensor, the management server or at a combination of the two

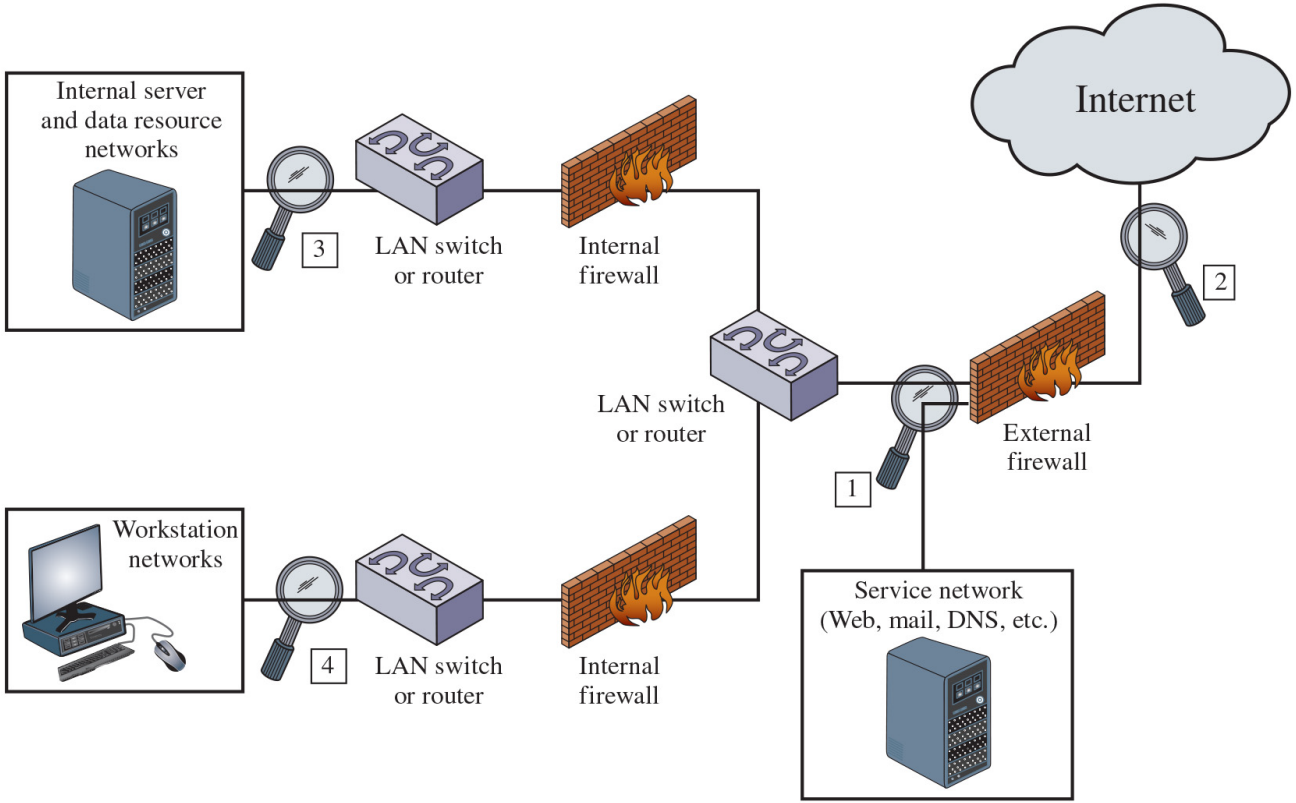


Passive NIDS Sensor



Source: Based on [CREM06].

Example of NIDS Sensor Deployment



Intrusion Detection Techniques

ATTACKS SUITABLE FOR SIGNATURE DETECTION

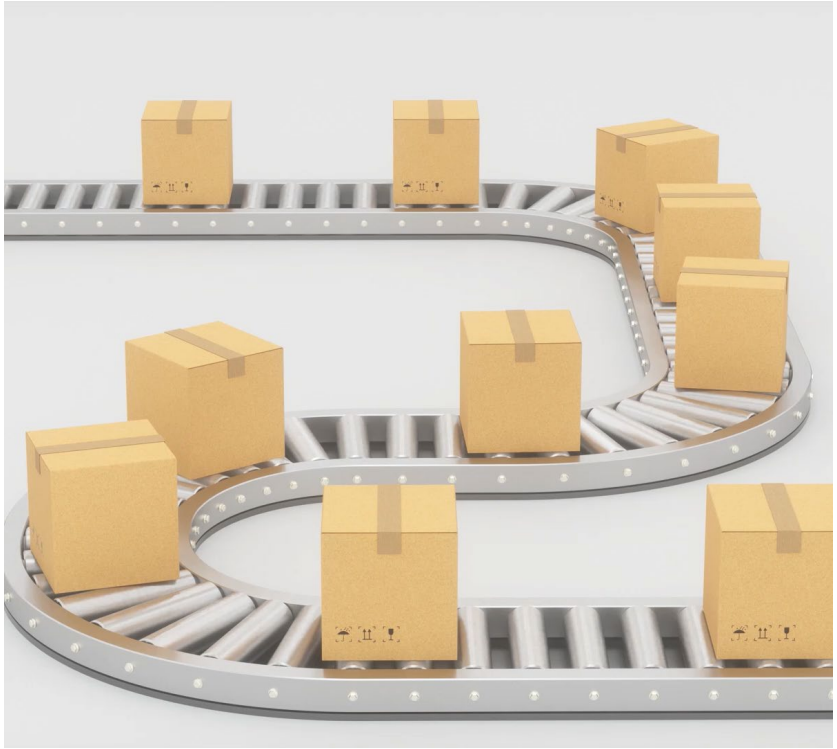
- Application layer reconnaissance and attacks
- Transport layer reconnaissance and attacks
- Network layer reconnaissance and attacks
- Unexpected application services
- Policy violations

ATTACKS SUITABLE FOR ANOMALY DETECTION

- Denial-of-service (D o S) attacks
- Scanning
- Worms

Stateful Protocol Analysis (SPA)

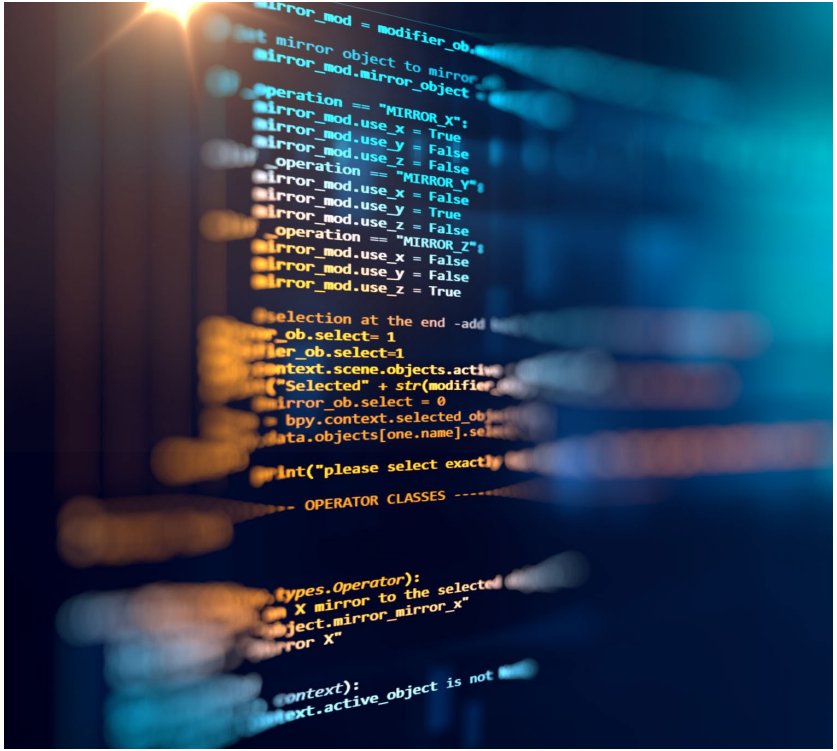
- Subset of anomaly detection that compares observed network traffic against predetermined universal vendor supplied profiles of benign protocol traffic
  - This distinguishes it from anomaly techniques trained with organization-specific traffic protocols
- Understands and tracks network, transport, and application protocol states to ensure that they progress as expected
- A key disadvantage is the high resource use it requires.



Logging of Alerts

Typical information logged by a NIDS sensor includes:

- Timestamp
- Connection or session ID
- Event or alert type
- Rating
- Network, transport, and application layer protocols
- Source and destination IP addresses
- Source and destination TCP or UDP ports, or ICMP types and codes
- Number of bytes transmitted over the connection
- Decoded payload data, such as application requests and responses
- State-related information



Intrusion Prevention Systems (IPS)



Also known as Intrusion Detection and Prevention System (IDPS)



Is an extension of an IDS that includes the capability to attempt to block or prevent detected malicious activity



Can be host-based, network-based, or distributed/hybrid

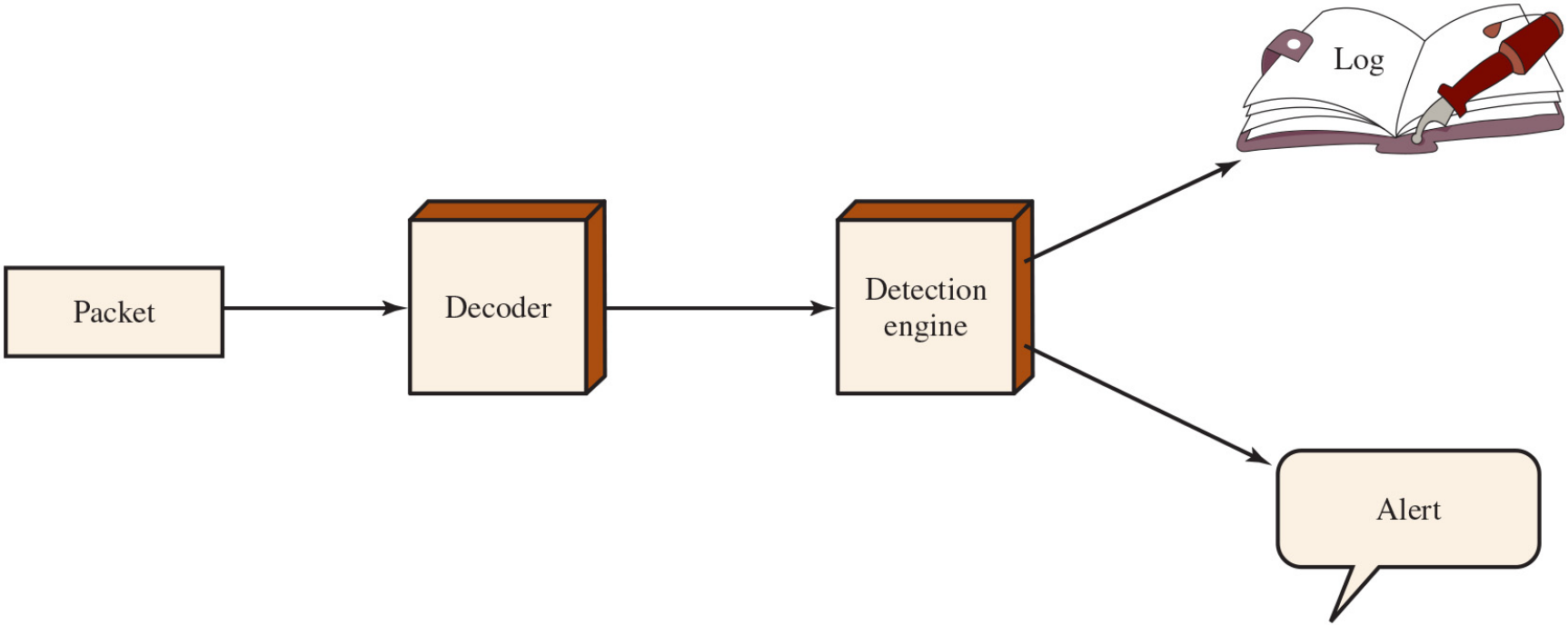


Can use anomaly detection to identify behavior that is not that of legitimate users or signature/heuristic detection to identify known malicious behavior



Can block traffic but makes use of the types of algorithms developed for IDSs to determine when to do so

Snort Architecture



Snort Rule Formats

Action	Protocol	Source IP address	Source port	Direction	Dest IP address	Dest port

(a) Rule header

Option keyword	Option arguments	. . .

(b) Options

https://www.snort.org/documents

Snort Rule Actions

Action	Description
alert	Generate an alert using the selected alert method, and then log the packet.
log	Log the packet.
pass	Ignore the packet.
activate	Alert and then turn on another dynamic rule.
dynamic	Remain idle until activated by an activate rule; then act as a log rule.
Drop	Make iptables drop the packet and log the packet.
reject	Make iptables drop the packet, log it, and then send a TCP reset if the protocol is TCP or an ICMP port unreachable message if the protocol is UDP.
sdrop	Make iptables drop the packet but do not log it.

Specialized Security Appliances

There are a variety of specialized security appliances available. Three examples are:

Appliance	Explanation
Cisco Advanced Malware Protection (AMP)	• An enterprise-class advanced malware analysis and protection solution • Provides comprehensive malware protection for organizations before, during, and after an attack • Accesses the collective security intelligence of the Cisco Talos Security Intelligence and Research Group
Cisco Web Security Appliance (WSA)	• A secure web gateway that combines leading protections to help organizations address the growing challenges of securing and controlling web traffic • Protects the network by automatically blocking risky sites and testing unknown sites before allowing users to access them • Provides malware protection, application visibility and control, acceptable use policy controls, insightful reporting, and secure mobility
Cisco Email Security Appliance (ESA)	• Defends mission-critical email systems • Constantly updated by real-time feeds from the Cisco Talos • Features include spam blocking, advanced malware protection, and outbound message control

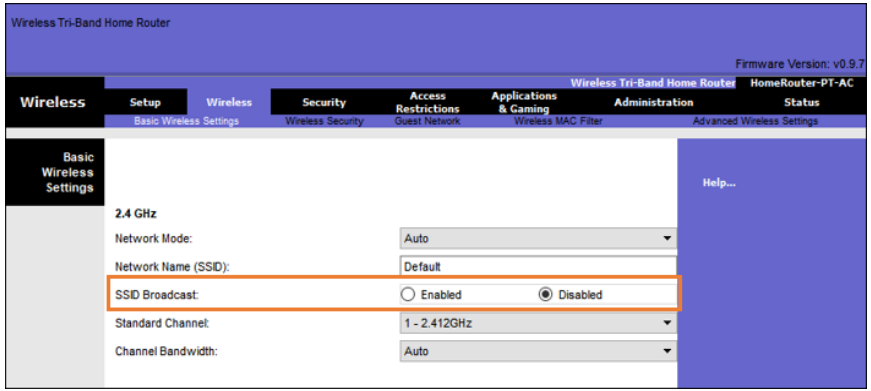
3. Securing Wireless Access

SSID Cloaking and MAC Address Filtering

To address the threats of keeping wireless intruders out and protecting data, two early security features were used and are still available on most routers and APs: SSID cloaking and MAC address filtering.

SSID Cloaking

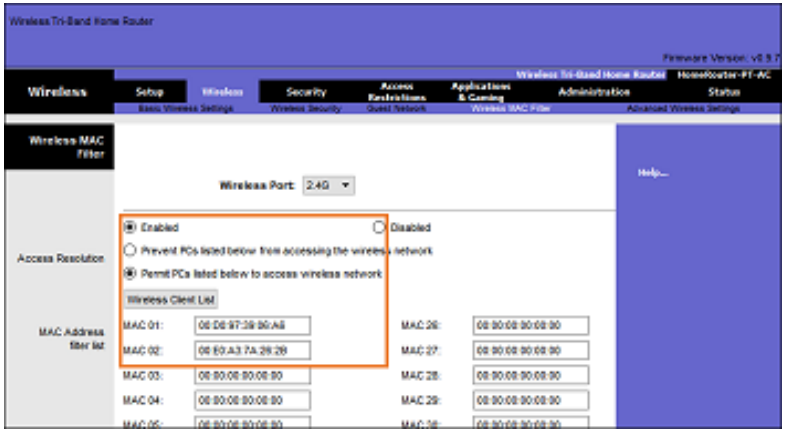
- APs and some wireless routers allow the SSID beacon frame to be disabled.
- Wireless clients must manually configure the SSID to connect to the network.



SSID Cloaking and MAC Address Filtering (Cont.)

MAC Addresses Filtering

- An administrator can manually permit or deny clients wireless access based on their physical MAC hardware address.
- In the figure, the router is configured to permit two MAC addresses. Devices with different MAC addresses will not be able to join the 2.4GHz WLAN.



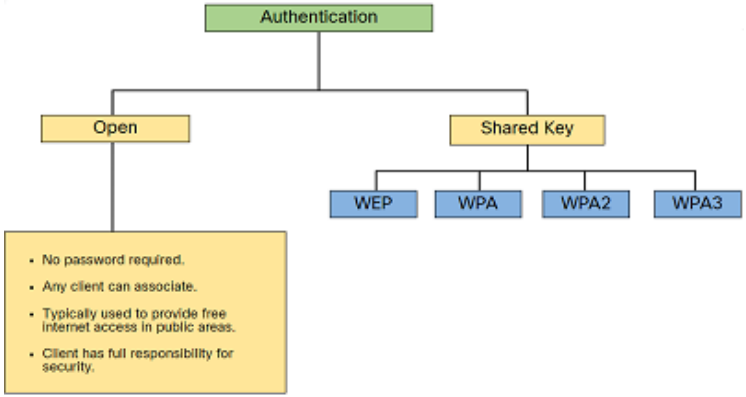
802.11 Original Authentication Methods

SSIDs are easily discovered even if APs do not broadcast them, and MAC addresses can be spoofed.

The best way to secure a wireless network is to use authentication and encryption systems.

Two types of authentication were introduced with the original 802.11 standard:

- **Open system authentication** - Any wireless client can easily connect and should only be used when security is of no concern.
- **Shared key authentication** - Provides mechanisms (WEP, WPA, WPA2, and WPA3) to authenticate and encrypt data between a wireless client and AP.



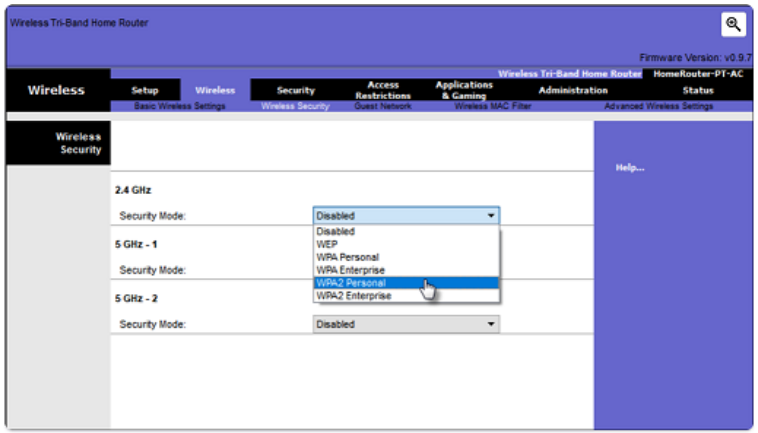
Shared Key Authentication Methods

There are four shared key authentication techniques available. Until the availability of WPA3 devices becomes ubiquitous, wireless networks should use the WPA2 standard.

Authentication Method	Description
Wired Equivalent Privacy (WEP)	The original 802.11 specification designed to secure the data using the Rivest Cipher 4 (RC4) encryption method with a static key. However, the key never changes when exchanging packets. This makes it easy to hack. WEP is no longer recommended and should never be used.
Wi-Fi Protected Access (WPA)	A Wi-Fi Alliance standard that uses WEP but secures the data with the much stronger Temporal Key Integrity Protocol (TKIP) encryption algorithm. TKIP changes the key for each packet, making it much more difficult to hack.
WPA2	WPA2 is the current industry standard for securing wireless networks. It uses the Advanced Encryption Standard (AES) for encryption. AES is currently considered the strongest encryption protocol.
WPA3	The next generation of Wi-Fi security, WPA3-enabled devices use the latest security methods, disallow outdated legacy protocols, and require the use of Protected Management Frames (PMF). However, devices with WPA3 are not yet readily available.

Authenticating a Home User

Home routers typically have two choices for authentication: WPA and WPA2 (stronger). Two WPA2 authentication methods are:



Personal

- Intended for home or small office networks, users authenticate using a pre-shared key (PSK).

- Wireless clients authenticate with the wireless router using a pre-shared password.

Enterprise

- Intended for enterprise networks but requires a Remote Authentication Dial-In User Service (RADIUS) authentication server.

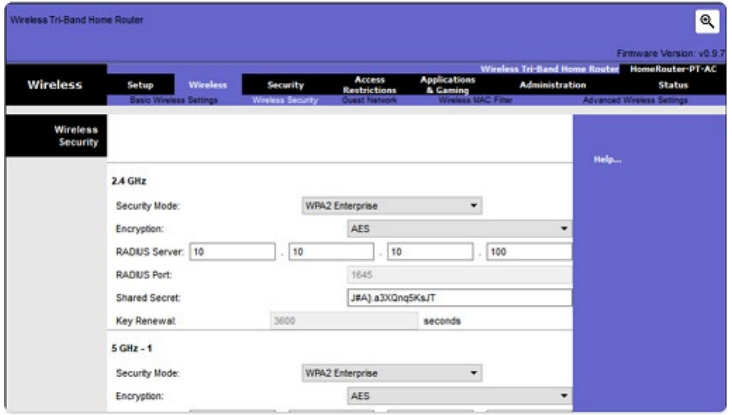
- The device must be authenticated by the RADIUS server and then users must authenticate using 802.1X standard Extensible Authentication Protocol (EAP).

Authentication in the Enterprise

In networks that have stricter security requirements, an additional authentication or login is required to grant wireless clients such access.

The Enterprise security mode choice requires an Authentication, Authorization, and Accounting (AAA) RADIUS server.

- RADIUS Server IP address: The reachable address of the RADIUS server.
- UDP port numbers: Officially assigned UDP ports 1812 for RADIUS Authentication, and 1813 for RADIUS Accounting, but can also operate using UDP ports 1645 and 1646.
- Shared key - Used to authenticate the AP with the RADIUS server.



4. Security Services

Traffic Control with ACLs

An Access Control List (ACL) is a series of commands that control whether a device forwards or drops packets based on information found in the packet header. ACLs perform the following tasks:

- They limit network traffic to increase network performance.
- They provide traffic flow control.
- They provide a basic level of security for network access.
- They filter traffic based on traffic type
- They screen hosts to permit or deny access to network services.

In addition to either permitting or denying traffic, ACLs can be used for selecting types of traffic to be analyzed, forwarded, or processed in other ways.

ACLs: Important Features

Two types of IPv4 ACLs are standard and extended.

Standard ACLs can be used to permit or deny traffic only from source IPv4 addresses. The destination of the packet and the ports involved are not evaluated.

Extended ACLs filter IPv4 packets based on several attributes that include:

- Protocol type
- Source IPv4 address
- Destination IPv4 address
- Source TCP or UDP ports
- Destination TCP or UDP ports
- Optional protocol type information for finer control

ACLs: Important Features (Cont.)

- Standard and extended ACLs can be created using either a number or a name to identify the ACL and its list of statements.

- By configuring ACL logging, an ACL message can be generated and logged when traffic meets the permit or deny criteria defined in the ACL.

- Cisco ACLs can also be configured to only allow TCP traffic that has an ACK or RST bit set, so that only traffic from an established TCP session is permitted. This can be used to deny any TCP traffic from outside the network that is trying to establish a new TCP session.

SNMP

- Simple Network Management Protocol (SNMP) allows administrators to manage end devices such as servers, workstations, routers, switches, and security appliances, on an IP network.
- It enables network administrators to monitor and manage network performance, find and solve network problems, and plan for network growth.
- The SNMP system consists of two elements:
  - SNMP manager that runs SNMP management software
  - SNMP agents which are the nodes being monitored and managed
- The Management Information Base (MIB) is a database on the agents that stores data and operational statistics about the device.
- The SNMP manager is part of a network management system (NMS).
- The SNMP manager can collect information from an SNMP agent by using the “get” action and can change configurations on an agent by using the “set” action.
- In addition, SNMP agents can forward information directly to a network manager by using “traps”.

NetFlow

- A Cisco IOS technology that provides statistics on packets flowing through a Cisco router or multilayer switch.
- NetFlow provides data to enable network and security monitoring, network planning, traffic analysis to include identification of network bottlenecks, and IP accounting for billing purposes.
- NetFlow technology distinguishes packet flows using a combination of seven fields:
  - Source IP address
  - Destination IP address
  - Source port number
  - Destination port number
  - Layer 3 protocol type
  - Type of Service (ToS) marking
  - Input logical interface

Port Mirroring

- **Packet analyzer (packet sniffer or traffic sniffer) limitation** - because network switches can isolate traffic, traffic sniffers or other network monitors, such as IDS, cannot access all the traffic on a network segment.

- **Port mirroring** is a feature that allows a switch to make duplicate copies of traffic passing through a switch, and then send it out a port with a network monitor attached. The original traffic is forwarded in the usual manner.

Syslog

- When certain events occur on a network, networking devices have trusted mechanisms to notify the administrator with detailed system messages.
- Network administrators have a variety of options for storing, interpreting, and displaying these messages, and for being alerted to those messages.
- Syslog protocol is the most common method of accessing system messages.

- The syslog logging service provides three primary functions:
  - The ability to gather logging information for monitoring and troubleshooting
  - The ability to select the type of logging information that is captured
  - The ability to specify the destination of captured syslog messages

NTP

- Network Time Protocol (NTP) is important to synchronize the time across all devices on the network. When the time is not synchronized between devices, it will be impossible to determine the order of the events that have occurred in different parts of the network.

- As a network grows, it becomes difficult to ensure that all infrastructure devices are operating with synchronized time.

- A solution to keep time setting synchronized is configuring the Network Time Protocol (NTP).

- NTP protocol allows routers on the network to synchronize their time settings with an NTP server.

- A group of NTP clients that obtain time and date information from a single source have more consistent time settings.

NTP (Cont.)

NTP networks use a hierarchical system of time sources. Each level in this hierarchical system is called a stratum.

NTP servers are arranged in three levels known as strata:

- **Stratum 0** - An NTP network gets the time from authoritative time sources. These authoritative time sources, also referred to as stratum 0 devices, are high-precision timekeeping devices assumed to be accurate and with little or no delay associated with them.
- **Stratum 1** -The stratum 1 devices are directly connected to the authoritative time sources. They act as the primary network time standard.
- **Stratum 2 and lower strata** - The stratum 2 servers are connected to stratum 1 devices through network connections. Stratum 2 devices, such as NTP clients, synchronize their time using the NTP packets from stratum 1 servers. They could also act as servers for stratum 3 devices.

AAA Servers

Three independent security functions provided by the AAA architectural framework are authentication, authorization, and accounting.

AAA Provides	Description
Authentication	• Users and administrators must prove that they are who they say they are. • Authentication can be established using username and password combinations, challenge and response questions, token cards, and other methods. • AAA authentication provides a centralized way to control access to the network.
Authorization	• After the user is authenticated, authorization services determine which resources the user can access and which operations the user is allowed to perform.
Accounting	• Accounting records what the user does, including what is accessed, the amount of time the resource is accessed, and any changes that were made. • Accounting keeps track of how network resources are used.

AAA Servers (Cont.)

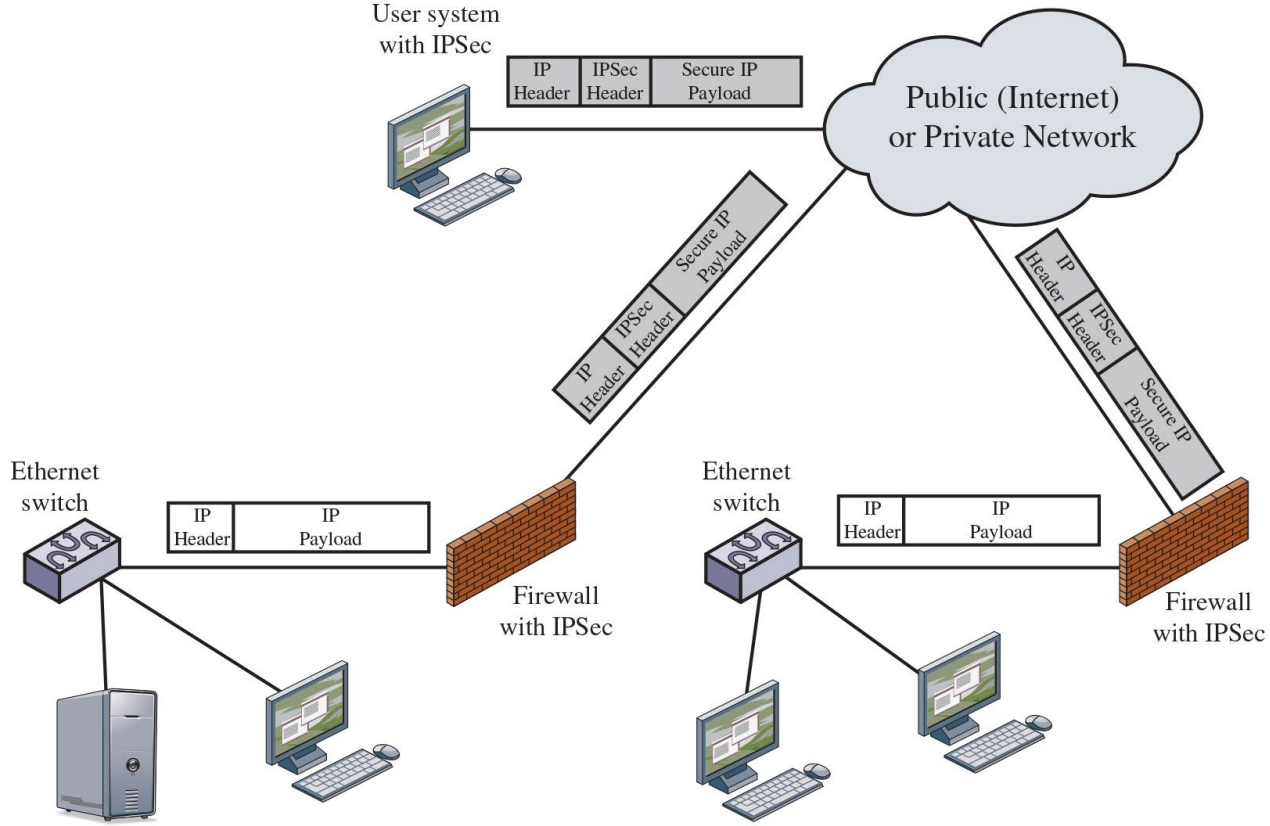
Terminal Access Controller Access-Control System Plus (TACACS+) and Remote Authentication Dial-In User Service (RADIUS) are both authentication protocols used to communicate with AAA servers.

	TACACS+	RADIUS
Functionality	Separates AAA according to the AAA architecture, allowing modularity of the security server implementation	Combines authentication and authorization but separates accounting, allowing less flexibility in implementation than TACACS+
Standard	Mostly Cisco supported	Open/RFC standard
Transport	TCP, 49	UDP,1812 for authentication and 1813 for accounting
Protocol CHAP	Bidirectional challenge and response as used in Challenge Handshake Authentication Protocol (CHAP)	Unidirectional challenge and response from the RADIUS security server to the RADIUS client
Confidentiality	Entire packet encrypted	Password encrypted
Customization	Provides authorization of router commands on a per-user or per-group basis	Has no option to authorize router commands on a per-user or per-group basis
Accounting	Limited	Extensive

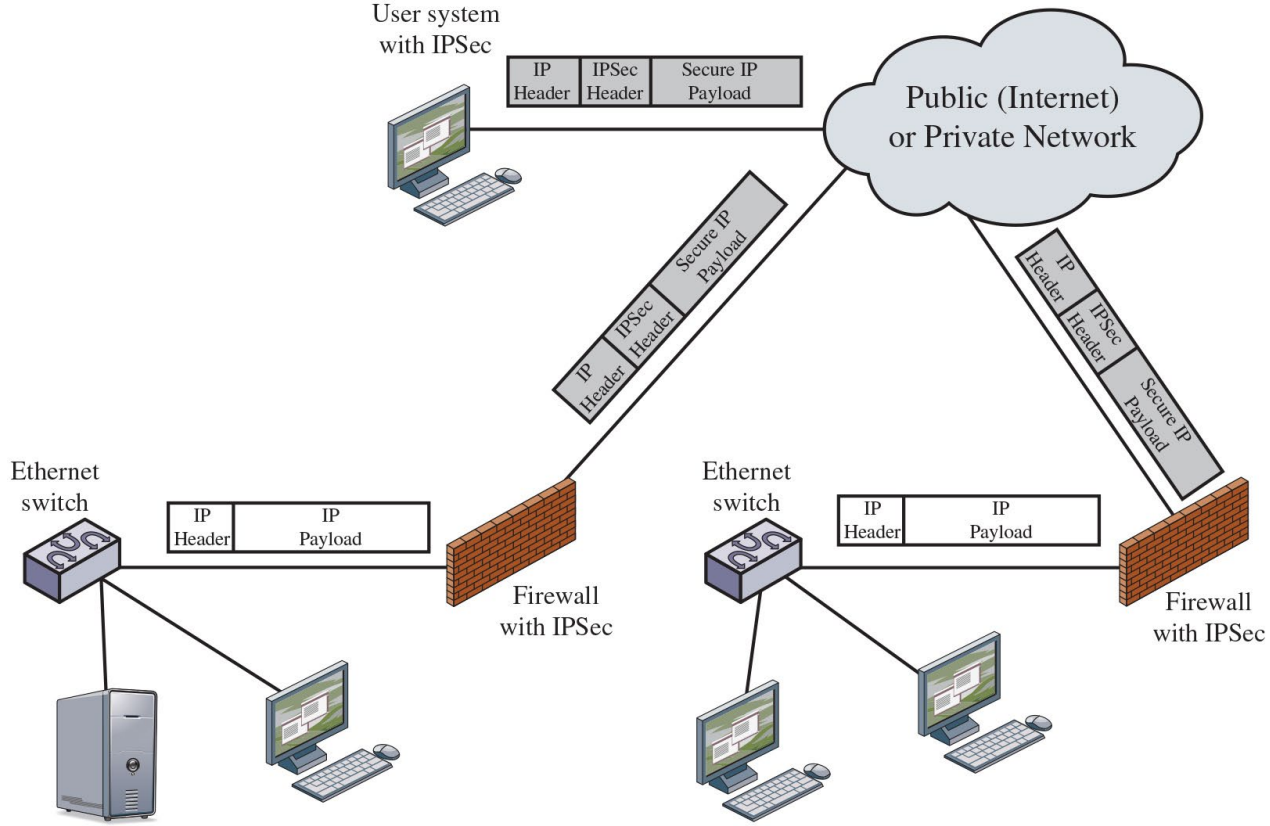
VPN

- A virtual private network (VPN) is a private network that is created over a public network, usually the internet. VPN uses virtual connections that are routed through the internet from the organization to the remote site.
- A VPN connects two endpoints, such as a remote office to a central office, over a public network, to form a logical connection. The logical connections can be made at either Layer 2 or Layer 3.
- A VPN is private in that the traffic is encrypted to keep the data confidential while it is transported across the public network.
- Common examples of Layer 3 VPNs are GRE, Multiprotocol Label Switching (MPLS), and IPsec.
- Layer 3 VPNs can be point-to-point site connections, such as GRE and IPsec, or they can establish any-to-any connectivity to many sites using MPLS.
- VPNs are commonly deployed in a **site-to-site** topology to securely connect central sites with remote locations. They are also deployed in a **remote-access** topology to provide secure remote access to external users travelling or working from home.

A VPN Security Scenario



A VPN Security Scenario



5. Types of Security Data

Alert Data

- Alert Data consists of messages generated by IPSs or IDSs in response to traffic that violates a rule or matches the signature of a known exploit.

- A network IDS (NIDS), such as Snort, comes configured with rules for known exploits.

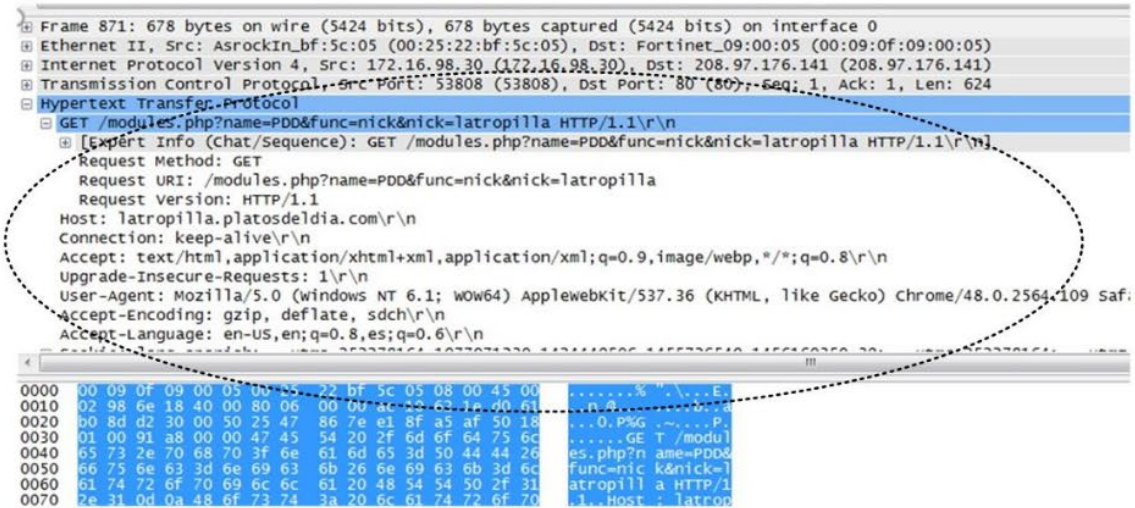
- Alerts are generated by Snort and are made readable and searchable various Network Security Monitoring (NSM) tools (Zeek, Security Onion)

- A testing site used to determine if Snort is operating is the tesmyids site.
  - It consists of a single webpage that displays only **uid=0(root) gid=0(root) groups=0(root)**.
  - If Snort is operating correctly and a host visits this site, a signature will be matched, and an alert will be triggered.
  - This is an easy and harmless way to verify that the NIDS is running.

Session and Transaction Data

- Session data is a record of a conversation between two network endpoints (often a client and a server).
- The server could be inside the enterprise network or at a location accessed over the internet.
- Session data is data about the session, not the data retrieved and used by the client.
- It will include identifying information such as **the five tuples** of source and destination IP addresses, source and destination port numbers, and the IP code for the protocol in use.
- Data about the session typically includes a session ID, the amount of data transferred by source and destination, and information related to the duration of the session.
- The figure on the following slide shows a partial output for HTTP sessions from a Zeek (a network security monitoring tool) connection log.

PCAP HTTP data



Zeek

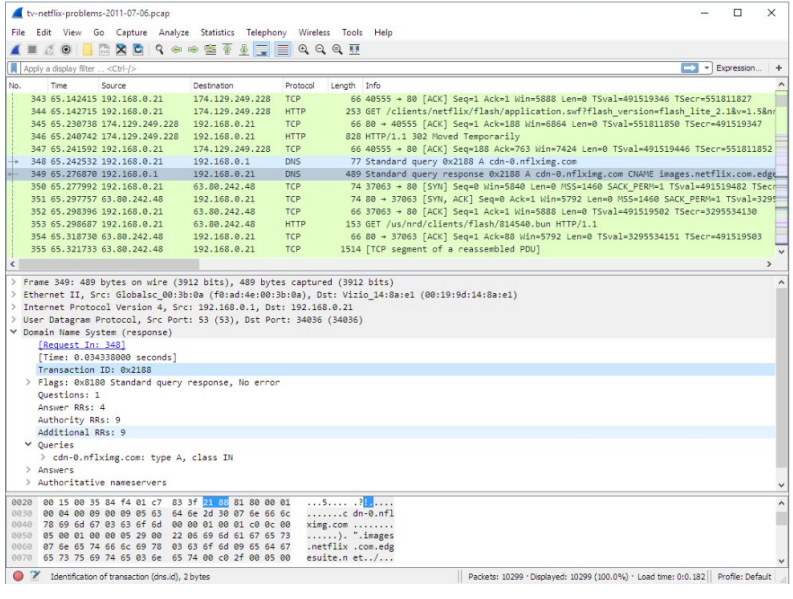
http.log | HTTP request/reply details

FIELD	TYPE	DESCRIPTION
ts	time	Timestamp for when request happened
uid & id		Underlying connection info > See conn.log
trans_depth	count	Pipelined depth into connection
method	string	Verb used in HTTP request (GET, POST, etc.)
host	string	Value of HOST header
uri	string	URI used in request
referrer	string	Value of referer header
version	string	Value of version portion of request
user_agent	string	Value of User-Agent header from client
origin	string	Value of Origin header from client
request_body_len	count	Uncompressed data size from client
response_body_len	count	Uncompressed data size from server
status_code	count	Status code returned by server
status_msg	string	Status message returned by server
info_code	count	Last seen 1xx info reply code from server
info_msg	string	Last seen 1xx info reply message from server
tags	table	Indicators of various attributes discovered
username	string	Username if basic-auth performed for request
password	string	Password if basic-auth performed for request
proxied	table	All headers indicative of proxied request
orig_fuids	vector	Ordered vector of file unique IDs
orig_filenames	vector	Ordered vector of filenames from client
orig_mime_types	vector	Ordered vector of mime types
resp_fuids	vector	Ordered vector of file unique IDs
resp_filenames	vector	Ordered vector of filenames from server
resp_mime_types	vector	Ordered vector of mime types
client_header_names	vector	Vector of HTTP header names sent by client
server_header_names	vector	Vector of HTTP header names sent by server
cookie_vars	vector	Variable names extracted from all cookies
uri_vars	vector	Variable names from URI

Source: https://www.cronin ity.com/post/network-security-monitoring-

Full Packet Captures

- Full packet captures are the most detailed network data that is generally collected, and the most storage and retrieval intensive types of data used in NSM.
- They contain data about network conversations (session data), the actual contents of the conversations, the text of email messages, the HTML in webpages, and the files that enter or leave the network.
- Extracted content can be recovered from full packet captures and analyzed for malware or user behavior that violates business and security policies.



Statistical Data

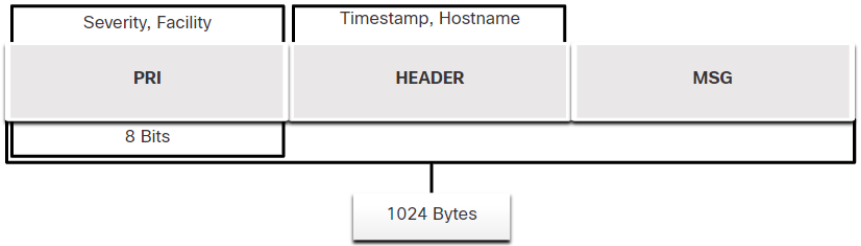
- Statistical data is about network traffic and created through the analysis of other forms of network data.
- Statistical characteristics of normal network behavior can be compared to current network traffic to detect anomalies.
- Statistics can be used to characterize normal amounts of variation in network traffic patterns to identify network conditions that are significantly outside of those ranges.
- Statistically significant differences should raise alarms and prompt investigation.
- Network Behavior Analysis (NBA) and Network Behavior Anomaly Detection (NBAD) are approaches to network security monitoring that use advanced analytical techniques to analyze NetFlow or Internet Protocol Flow Information Export (IPFIX) network telemetry data.
- Techniques such as predictive analytics and artificial intelligence perform advanced analyses of detailed session data to detect potential security incidents.

Host Logs

- Host-based intrusion detection systems (HIDS) can detect and prevent intrusions.
- It creates logs and stores them on the host and many host-based protections have a way to submit logs to centralized log management servers.
- HIDS systems can use agents to submit logs to management servers and the logs can be searched from a central location using NSM tools.
- Microsoft Windows host logs are visible locally through Event Viewer, which keeps five types of logs:
  - **Application logs** – They contain events logged by various applications.
  - **System logs** – They include events regarding the operation of drivers, processes, and hardware.
  - **Setup logs** – They record information about the installation of software, including Windows updates.
  - **Security logs** – They record events related to security, such as logon attempts and operations related to file or object management and access.
  - **Command-line logs** - Attackers who have gained access to a system, and some types of malware, execute commands from the CLI rather than a GUI.
- Various logs can have different event types.
- Security logs consist only of audit success or failure messages.

Syslog

- Syslog includes specifications for message formats, a client-server application structure, and network protocol.
- Many different types of network devices can be configured to use the syslog standard to log events to centralized syslog servers.
- The Syslog sender sends a small (less than 1KB) text message to the Syslog receiver ("syslogd", "Syslog daemon," or "Syslog server").
- Syslog messages can be sent via UDP (port 514) and/or TCP (typically, port 5000), typically in plaintext over the network.
- A Syslog message seen on the network has three distinct parts:.
  - **PRI** (priority): two elements, the Facility and Severity of the message (integer values).
  - **HEADER**: the timestamp in *MMM DD HH:MM:SS* format, and the hostname or IP address of the device that is the source of the message.
  - **MSG** (message text): the meaning of the syslog message.



SIEM and Log Collection

- Security Information and Event Management (SIEM) technology is used in many organizations to provide real-time reporting and long-term analysis of security events.
- It combines the essential functions of security event management (SEM) and security information management (SIM) to provide a comprehensive view of the enterprise network using functions:
  - **Log collection** – Collects event records from sources throughout the organization.
  - **Normalization** – Maps log messages from different systems into a common data model.
  - **Correlation** – Links logs and events from disparate systems or applications.
  - **Aggregation** – Reduces the volume of event data by consolidating duplicate event records.
  - **Reporting** – Presents the correlated, aggregated event data in real-time monitoring and long-term summaries, including graphical interactive dashboards.
  - **Compliance** – Reports to satisfy the requirements of various compliance regulations.

